

🔗 "Secure Project" 모의 해킹 실습 환경 구축 최종 가이드이 가이드는 KISA 문서를 기반으로 한 중소기업 보안 취약점 분석 프로젝트를 위해, "공격자 PC" 1대와 "가상 피해 서버" 5대를 구축하는 것을 목표로 합니다.

최종 구성도:

공격자 (Attacker): 칼리 리눅스 (VMware/VirtualBox 가상 머신)

피해자 (Victim): 사용자 PC(WSL)에서 실행되는 5개의 도커 컨테이너

dmin_entry: 서버 제공 회사 (직접 만든 관리 페이지)

client_a_OWASP: A 고객사 (Juice Shop)

client_b_dwva: B 고객사 (DVWA)

client_c_bwapp: C 고객사 (bWAPP)

key_vault_server: 암호키 서버 (Vault)

전제:

공격자: 서버를 제공해주는 회사에서 각 회사에 서버를 관리페이지를 주어서 그걸 바탕으로 각 회사에서 확인한다는 것을 알았어, 공격을 하려고해 공격은 각회사의 페이지로도 공격을 하고 관리자 페이지를 공격해서 구조 파악을 하고 서버간의 구조를확인하여 백도어를 열어 공격도 하는 방식도 넣고 싶어

1단계: 필수 프로그램 설치 (Host PC)Docker Desktop 설치: Docker Desktop 공식 사이트에서 설치합니다. (설치 시 "Use WSL 2" 옵션이 기본으로 체크되어 있는지 확인합니다.)

VMware Workstation Player 설치: VMware Player 다운로드 페이지에서 무료 버전을 설치합니다. (VirtualBox도 무방합니다.)

VS Code 설치: Visual Studio Code 공식 사이트에서 설치하고, WSL 확장 프로그램을 반드시 설치합니다.

[vm 칼리 설치]

2단계: "공격자 PC" (칼리 리눅스) 설정칼리 VM 이미지 다운로드: Kali Linux 공식 사이트로 이동하여 "Virtual Machines" 탭을 선택하고 ****VMware****용 이미지를 다운로드합니다. (.ova 또는 .zip 파일)

VM 불러오기: VMware Player를 실행하고 File > Open a Virtual Machine을 선택하여 다운로드한 칼리 VM 파일을 엽니다.

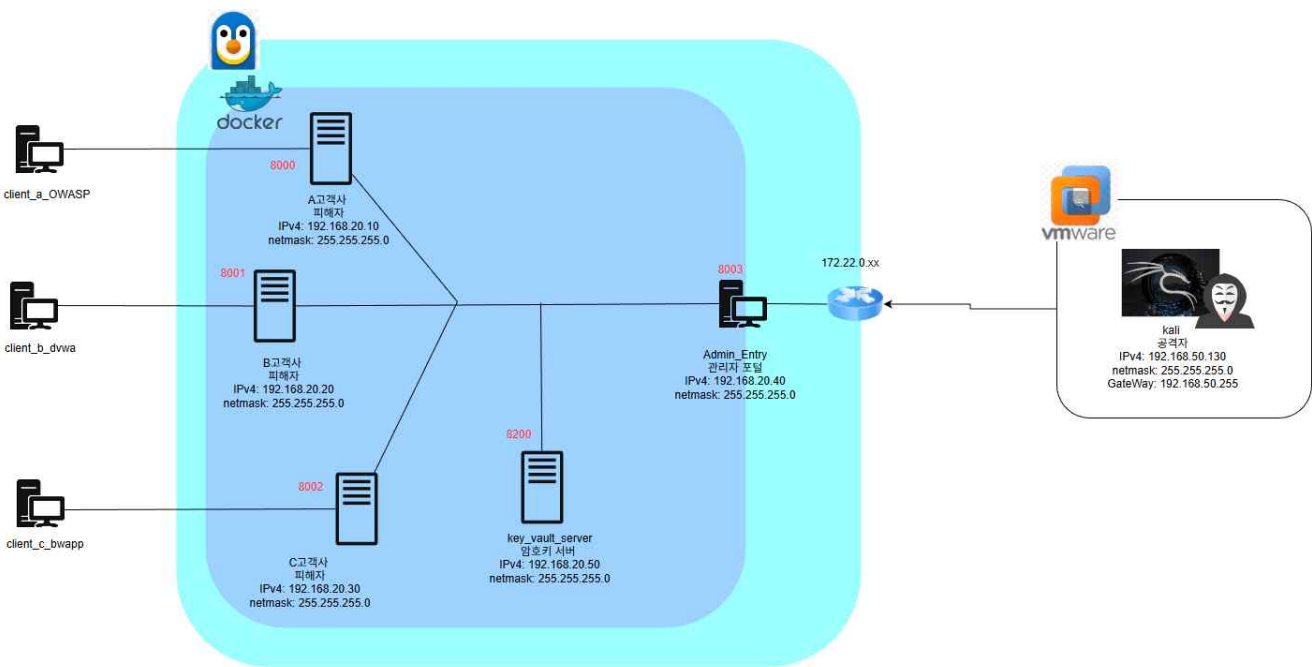
네트워크 설정 (필수!): 칼리 VM을 시작하기 전에, VM 설정(Edit virtual machine settings)으로 들어갑니다.Network Adapter를 NAT에서 ****Bridged (Connected directly to the physical network)****로 변경합니다.

VM 실행: 칼리 VM을 시작하고 로그인합니다. (기본 ID: kali / PW: kali)

🐧 WSL에 도커를 올려야 하는 이유
가장 큰 이유는 "컨테이너는 원래 리눅스 기술이기 때문입니다."

- 비유 (PS5 게임): 리눅스용 도커 컨테이너는 "플레이스테이션 5 게임"과 같습니다. 이 게임은 "PS5 기기"(리눅스 커널)에서만 돌아갑니다.
- 윈도우 PC: 사용자님의 윈도우 PC는 "닌텐도 스위치"(윈도우 커널)와 같습니다. "PS5 게임"을 닌텐도에서 실행할 수는 없습니다.
- WSL 2의 역할: "PS5 에뮬레이터"입니다. 윈도우 안에 리눅스 커널(PS5)을 설치해서, "PS5 게임"(리눅스 컨테이너)이 돌아갈 수 있는 환경을 만들어주는 것입니다.

우리가 사용하는 Juice Shop, DVWA, Vault, httpd 등은 **모두 리눅스 환경에서 작동하도록 만들어진 컨테이너(게임)**입니다. 따라서 윈도우에서 이들을 실행하려면 반드시 WSL 2라는 "에뮬레이터"가 필요합니다.



[아이디 비번]

	[kali]	[ADMIN_entry]	[client_a_OWASP]	[client_b_dvwa]	[client_c_bwapp]	[key_vault_server]
ID	kali	admin		admin	bee	my_root_token
PW	kali	qhdkSDLchlRh		password	bug	

[피해자 서버]

[설치]

※wsl 설치 완료 후※

---파일 생성---

하나의 프로젝트로 묶는다는 개념

---이미지 생성---

Dockerfile: 하여 하나의 컨테이너를 올리는 방법 /네트워크 별도 지정해줘야함

docker-compose.yml: 파일을 통해 프로젝트를 한꺼번에 올린다.

---변경 및 구성---

이미지 파일을 손대서 고쳐야한다. --> VS 코드를 활용하여 수정하고 고칠 것이다.

---WSL 커널---

test@DESKTOP-JF6ACKA:~\$ mkdir SME_ATTACK_LAB

test@DESKTOP-JF6ACKA:~/SME_ATTACK_LAB\$ cd SME_ATTACK_LAB

test@DESKTOP-JF6ACKA:~/SME_ATTACK_LAB\$ mkdir admin_src

test@DESKTOP-JF6ACKA:~/SME_ATTACK_LAB\$ vi docker-compose.yml

파일 1: docker-compose.yml(모든 서버의 총 설계도입니다.)YAMLversion: '3.8'

※docker-compose파일 참고

--- 2. A 고객사 (OWASP Juice Shop) ---

client_a_OWASP:

image: bkimminich/juice-shop

container_name: client_a_OWASP

ports:

- "8000:3000"

networks:

sme_internal_network:

ipv4_address: 192.168.20.10

파일 2: admin_src/index.htmlVS Code에서 SME_Attack_Lab 폴더 안에 admin_src라는 새 폴더를 만듭니다.admin_src 폴더 안에 index.html이라는 새 파일을 만듭니다.아래 코드를 붙여넣고 저장합니다.

[WSL 커널]

test@DESKTOP-JF6ACKA:~\$ cd admin_src

test@DESKTOP-JF6ACKA:~/SME_ATTACK_LAB/admin_src\$ vi index.php

※ index 참고

[WSL 커널]

test@DESKTOP-JF6ACKA:~/SME_ATTACK_LAB\$ docker down (기존 컨테이너 제거)

test@DESKTOP-JF6ACKA:~/SME_ATTACK_LAB\$ docker-compose up -d (변경된 컨테이너 재실행)

docker.desktop 생성 완료

☐	▼	●	sme_attack_lab	-	-	-		⋮	
☐		●	client_a_OWASP	29b830e042fe	bkimminict	8000:3000		⋮	
☐		●	admin_entry	ea0769dfbbec	httpd:latest	8003:80		⋮	
☐		●	client_c_bwapp	8dd9905861ab	raesene/bv	8002:80		⋮	
☐		●	key_vault_server	d558bec02022	hashicorp/	8200:8200		⋮	
☐		●	client_b_dvwa	c1b19b6a0bee	sagikazarm	8001:80		⋮	

[윈도우 cmd]

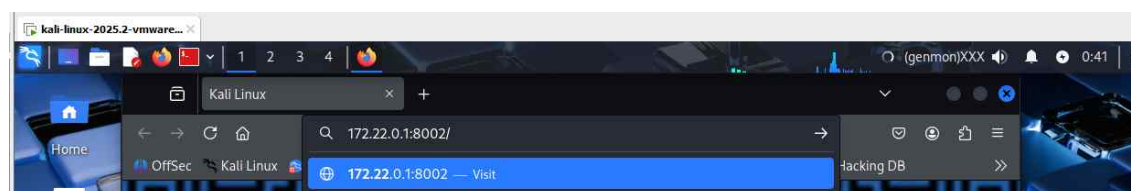
```
C:\Users\User>ipconfig

Windows IP 구성

이더넷 어댑터 vEthernet (WSL):

   연결별 DNS 접미사. . . . . : 
   링크-로컬 IPv6 주소. . . . . : fe80::c8d3:66b2:d7e8:91ea%33
   IPv4 주소. . . . . : 172.22.0.1
   서브넷 마스크. . . . . : 255.255.240.0
   기본 게이트웨이. . . . . :
```

[칼리에서 접속]



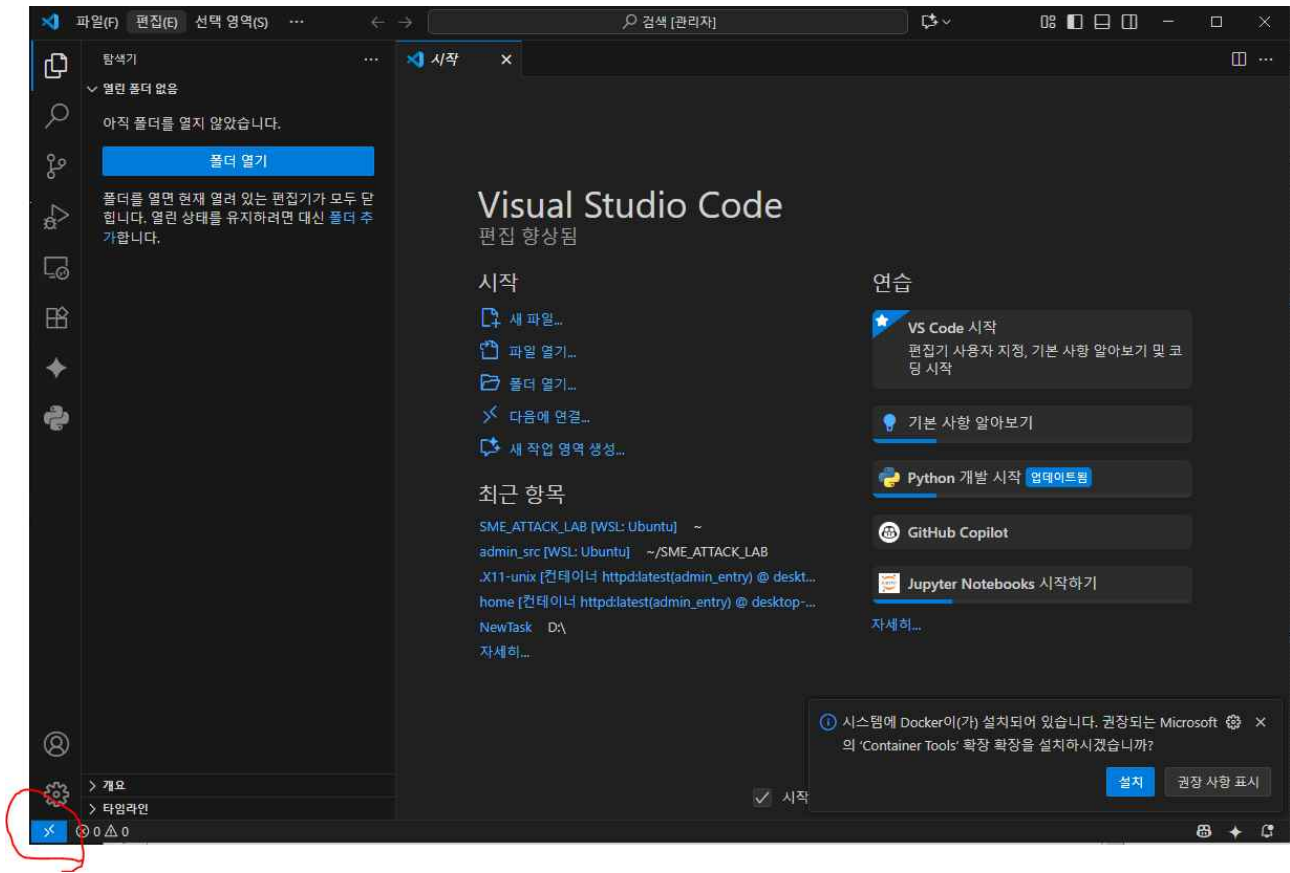
port를 변경해가면서 연결 하면됨

4단계: 전체 환경 실행Docker Desktop이 윈도우에서 실행 중인지 확인합니다.VS Code의 터미널 (WSL 터미널)을 엽니다. (SME_Attack_Lab 폴더가 열린 상태)터미널에 다음 명령어를 입력하여 5대의 피해자 서버를 실행합니다. (처음에는 이미지 다운로드로 2~5분 정도 걸립니다.) docker-compose up -d

5단계: 최종 접속 및 실습 시작Host PC (피해자 서버) IP 확인:윈도우 cmd 창에 ipconfig를 입력하고 IPv4 주소를 확인합니다. (예: 192.168.50.10)칼리 리눅스(공격자)에서 접속:칼리 VM의 Firefox 브라우저에서 아래 주소들로 접속합니다. ([Host PC IP]는 1번에서 찾은 IP로 변경)서비스접속 주소 (칼리 브라우저)기본 ID/PW관리자 포털http://[Host PC IP]:8003(없음)A 고객사 (Juice Shop)http://[Host PC IP]:8000(해킹 필요)B 고객사 (DVWA)http://[Host PC IP]:8001admin / passwordC 고객사 (bWAPP)http://[Host PC IP]:8002bee / bug암호키 서버 (Vault)http://[Host PC IP]:8200Token: my_root_token(최초 설정):DVWA (8001): 로그인 후 "Create / Reset Database" 버튼 클릭.bWAPP (8002): .../install.php에 접속 후 "here" 링크 클릭.

[vscode와 연결법]

※ vscode--> 확장--->wsl, DEV container, remote development 다운



1. wsl 연결 선택
2. 폴더열기 선택시 아까 이미지 파일 SME_ATTACK_LAB 선택 --> 확인
3. 여기서부터 index파일은 우리가 admin_entry만든 것 html로 홈페이지 꾸미면 됨
4. docker-compose.yml은 우리가 구성이 추가되거나 바뀌면 추가 하면됨

※index파일 변경후에는 F5로 계속 홈페이지 확인가능

-이유-

volumes:

- ./admin_src:/usr/local/apache2/htdocs/

docker-compose.yml 할 때 실시간 동기화로 설정함

※ docker-compose.yml 파일은 다시 설정

[WSL 커널]

test@DESKTOP-JF6ACKA:~/SME_ATTACK_LAB\$ docker down (기존 컨테이너 제거)

test@DESKTOP-JF6ACKA:~/SME_ATTACK_LAB\$ docker-compose up -d (변경된 컨테이너 재실행)

[WSL]

암호화 키 생성

1. Client A의 API 키 저장

```
docker-compose exec -e VAULT_TOKEN=my_root_token key_vault_server vault kv put secret/client_a  
api_key=JUICE_SHOP_SECRET_KEY_12345
```

2. Client B의 API 키 저장

```
docker-compose exec -e VAULT_TOKEN=my_root_token key_vault_server vault kv put secret/client_b  
api_key=DVWA_SUPER_SECRET_KEY_ABCDE
```

3. Client C의 API 키 저장

```
docker-compose exec -e VAULT_TOKEN=my_root_token key_vault_server vault kv put secret/client_c  
api_key=BWAPP_HIDDEN_KEY_XYZ987
```